

منصة شاهين الرقمية
سياسة إدارة الموقع الإلكتروني والتطبيق
نوفمبر 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الشمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيّد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة إدارة الموقع الإلكتروني والتطبيق			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
1SP0007			رقم المستند	
منصة شاهين الرقمية			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الاسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايخ	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management



1. المقدمة:

1.1 تُعد سياسة سياسة إدارة الموقع الإلكتروني والتطبيق جزءاً أساسياً في تنظيم عملية تطوير وإدارة وصيانة الموقع الإلكتروني والتطبيق بما يضمن الامتثال للضوابط التقنية والتنظيمية والأمنية الصادرة عن الجهات المختصة، وضمان حماية البيانات واستمرارية الخدمة والارتقاء بتجربة المستخدم.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو تحديد الضوابط والمعايير الحاكمة لإدارة وتشغيل وصيانة الموقع الإلكتروني والتطبيق، بما يضمن حماية البنية التحتية الرقمية والمحتوى العام من أي اختراق أو تعديل غير مصرح به، وضمان موثوقية ودقة وسلامة المعلومات المنشورة، والالتزام بمعايير التصميم الآمن وحماية البيانات الشخصية، وتعزيز تجربة المستخدم وضمان استقرار الخدمة واستمراريتها، وتوحيد إجراءات العمل بين الإدارات المسؤولة عن المحتوى والتقنية والأمن السيبراني.

3. تعاريف:

- 3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.
- 3.2 الموقع الإلكتروني: المنصة الرقمية العامة التي تُعرض من خلالها خدمات ومحتويات الشركة عبر الإنترنت.
- 3.3 التطبيق: البرنامج المخصص الذي يتيح للعملاء أو المستخدمين الوصول إلى خدمات الشركة عبر الأجهزة الذكية.
- 3.4 المستخدم: أي فرد مخول بالوصول إلى الموقع أو التطبيق سواء كان موظفاً أو عميلاً أو جهة خارجية معتمدة.
- 3.5 المحتوى: النصوص، الصور، الروابط، النماذج أو أي بيانات معروضة على الموقع أو التطبيق.
- 3.6 المدير التقني: الشخص المسؤول عن تشغيل وإدارة البنية التحتية التقنية وضمان سلامة الأنظمة الرقمية.
- 3.7 الأمن السيبراني: مجموعة الإجراءات والضوابط الهادفة لحماية الأنظمة الرقمية من التهديدات والهجمات الإلكترونية.
- 3.8 نظام إدارة المحتوى (CMS): النظام الداخلي الذي يتيح إنشاء وتحرير وتحديث محتوى الموقع أو التطبيق.
- 3.9 خطة الاستجابة للحوادث: الإجراءات المتبعة لمعالجة أي حادث أمني أو اختراق محتمل.
- 3.10 النسخ الاحتياطي: عملية حفظ نسخة من البيانات لضمان إمكانية استرجاعها في حال الفقد أو العطل.
- 3.11 المصادقة متعددة العوامل (MFA): آلية تحقق تعتمد أكثر من وسيلة لتأكيد هوية المستخدم قبل منحه صلاحية الدخول.

4. نطاق تطبيق السياسة:

4.1 تُطبق هذه السياسة على

- 4.1.1 موظفي الشركة الدائمين والمؤقتين.
- 4.1.2 المتعاقدين والمستشارين الخارجيين.
- 4.1.3 مزودي الخدمات التقنية وشركات الدعم الخارجي التي يُمنح أفرادها وصولاً لأي نظام تابع للشركة.

5. القطاعات والإدارات ذات العلاقة:

- 5.1 إدارة تقنية المعلومات .
- 5.2 قسم الأمن السيبراني.
- 5.3 إدارة المبيعات والتسويق.

6. الكيانات ذات العلاقة:

- 6.1 الهيئة الوطنية للأمن السيبراني (NCA)
- 6.2 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA)
- 6.3 هيئة الحكومة الرقمية (DGA)
- 6.4 هيئة التأمين السعودية



6.5 مزودو الخدمات التقنية الخارجيون، العملاء والمستخدمون النهائيون.

7. قواعد عامة:

7.1 الالتزام العام

- 7.1.1 يجب على جميع الموظفين والمتعاقدين والجهات الخارجية الالتزام بهذه السياسة عند إدارة أو تطوير أو تحديث محتوى الموقع الإلكتروني أو التطبيق.
- 7.1.2 يُلزم كل مستخدم أو مشرف بالنظام بالامتثال الكامل لضوابط الهيئة الوطنية للأمن السيبراني (NCA)، وهيئة الحكومة الرقمية (DGA)، وتعليمات هيئة التأمين فيما يخص حماية بيانات العملاء وإدارة الأنظمة الإلكترونية.
- 7.1.3 يجب ألا تُنفذ أي تغييرات في تصميم أو هيكل أو محتوى الموقع أو التطبيق إلا بعد الحصول على موافقة خطية من إدارة تقنية المعلومات.
- 7.1.4 يُحظر نشر أي محتوى أو ربط أنظمة خارجية دون مراجعة أمنية مسبقة.
- 7.1.5 تُراجع هذه السياسة بحد أدنى سنوياً لضمان توافقها مع أحدث المستجدات التقنية والتنظيمية.

7.2 إدارة المحتوى

- 7.2.1 يجب أن تُدار جميع عمليات النشر والتحديث في الموقع الإلكتروني والتطبيق من خلال إدارة تقنية المعلومات وبالتنسيق مع الجهة المالكة للمحتوى (إدارة المبيعات والتسويق) لضمان الدقة، الاتساق، والامتثال التنظيمي.
- 7.2.2 يُلزم بتوثيق جميع التعديلات على المحتوى ضمن سجل إلكتروني يتضمن: تاريخ النشر أو التحديث، اسم الشخص المنفذ، ونوع التعديل (إضافة، حذف، تعديل).
- 7.2.3 يجب أن يخضع المحتوى قبل نشره للمراجعة والموافقة من الجهة المختصة، لضمان توافقه مع سياسات الشركة، ومعايير حماية البيانات، ومتطلبات هيئة التأمين.
- 7.2.4 يُحظر نشر أي محتوى يتضمن معلومات حساسة، أو بيانات عملاء، أو تفاصيل تشغيلية داخلية غير مصرح بعرضها للعامة.
- 7.2.5 يجب على الفريق الفني التأكد من أن المحتوى المنشور آمن من أي تعليمات برمجية ضارة (Malicious Scripts) أو روابط غير موثوقة.
- 7.2.6 يُلزم بتحديث المحتوى بشكل دوري، وبحد أدنى مرة كل (6) أشهر، لضمان حداثة المعلومات وصحتها.
- 7.2.7 يجب أن تُتبع معايير تحسين تجربة المستخدم (UX) وسهولة التصفح عند تصميم وتحديث الصفحات والمكونات البصرية للموقع والتطبيق.
- 7.2.8 تُخضع جميع الملفات والوسائط المرفوعة للفحص الأمني قبل تحميلها إلى الخوادم لتفادي أي ثغرات أمنية أو فيروسات.
- 7.2.9 يُحظر تعديل أو حذف أي محتوى منشور دون موافقة مسبقة من مدير تقنية المعلومات أو من يفوضه رسمياً.
- 7.2.10 تُراجع إدارة تقنية المعلومات الأداء التشغيلي للموقع والتطبيق شهرياً، بما يشمل سرعة التحميل، الأعطال، واستقرار المحتوى الظاهر للمستخدمين.
- 7.2.11 يجب أن تُحفظ نسخة احتياطية من جميع المحتويات المنشورة قبل أي تعديل جوهري، مع إمكانية استعادتها عند الحاجة (Version Control).

7.3 التصميم والتطوير الآمن

- 7.3.1 يجب تطوير وصيانة الموقع والتطبيق وفقاً لمبدأ "التصميم الآمن" (Secure by Design) بما يشمل التحقق من صحة المدخلات، وإدارة الجلسات، والتحكم في الصلاحيات.
- 7.3.2 يُلزم فريق التطوير بتطبيق جميع التحديثات البرمجية (Patches & Updates) فور صدورهم وبعد اختبارها في بيئة معزولة.
- 7.3.3 يجب تنفيذ اختبارات اختراق (Penetration Tests) داخلية وخارجية لا تقل عن مرة سنوياً وبعد أي تحديث رئيسي.
- 7.3.4 يجب أن تخضع جميع المكونات (Plugins / APIs / Frameworks) للتدقيق الأمني قبل دمجها بالنظام.
- 7.3.5 يُمنع استخدام أي مكتبات أو أدوات تطوير مفتوحة المصدر دون تقييم أمنها واعتمادها رسمياً من إدارة تقنية المعلومات.

7.4 حماية البيانات والمحتوى العام

- 7.4.1 يجب حماية جميع البيانات المعروضة للعامة من أي تعديل أو استغلال غير مصرح به عبر ضوابط وصول صارمة (Access Control Lists).
- 7.4.2 يُلزم الفريق التقني باستخدام بروتوكولات اتصال مشفرة (TLS 1.2 أو أعلى).

- 7.4.3 يجب تنفيذ نسخ احتياطي يومي لتقاني لبيانات الموقع والتطبيق مع حفظ النسخ في موقع آمن ومعزول.
- 7.4.4 تُحظر برمجة أي نموذج إدخال بيانات عام دون ضوابط تحقق من صحة الإدخال (Input Validation).
- 7.4.5 تُراجع صلاحيات المستخدمين الإداريين شهرياً وتوقف أي حساب غير نشط لمدة (30) يوماً.
- 7.5 المراقبة والكشف عن الثغرات
- 7.5.1 يجب إجراء فحص دوري للثغرات الأمنية (Vulnerability Scanning) ربع سنوي على الأقل، وعلى كل مكون تقني ضمن الموقع أو التطبيق.
- 7.5.2 تُصنف الثغرات حسب درجة الخطورة (Critical / High / Medium / Low) ويُعالج الحرج منها خلال مدة لا تتجاوز (7) أيام عمل.
- 7.5.3 تُستخدم أدوات مراقبة متقدمة (SIEM / IDS / WAF) لرصد الأنشطة غير المصرح بها وتنبيه الفريق الأمني فوراً.
- 7.5.4 تُوثق جميع الثغرات الأمنية ونتائج معالجتها في سجل رسمي يخضع للمراجعة من إدارة الأمن السيبراني.
- 7.5.5 تُحدَّث معايير التكوين الآمن (Configuration Standards) دورياً بناءً على نتائج الفحص والاختبار.
- 7.6 إدارة التحديثات والإصلاحات
- 7.6.1 يُلزم فريق تقنية المعلومات بمراقبة إصدارات التحديثات الأمنية الصادرة من مزودي البرمجيات المعتمدين.
- 7.6.2 يجب اختبار التحديثات في بيئة تجريبية قبل تطبيقها في بيئة التشغيل الفعلية.
- 7.6.3 يُوثق تطبيق كل تحديث في سجل يشمل: اسم النظام، نوع التحديث، تاريخ التطبيق، والنتيجة.
- 7.6.4 يجب التأكد من نجاح تطبيق التصحيحات الأمنية من خلال اختبار ما بعد التحديث (Post-Deployment Verification).
- 7.6.5 تُراجع أنظمة النسخ الاحتياطي بعد كل عملية تحديث لضمان استقرار الأداء واستعادة البيانات عند الحاجة.
- 7.7 المراقبة والتدقيق
- 7.7.1 يجب تفعيل خاصية السجلات الأمنية (Logging) في جميع الأنظمة المرتبطة بالموقع والتطبيق.
- 7.7.2 تُرسل السجلات إلى نظام مركزي محمي وتُراجع أسبوعياً لاكتشاف أي سلوك غير اعتيادي.
- 7.7.3 تُستخدم أدوات مراقبة سلامة الملفات (File Integrity Monitoring) لاكتشاف التغييرات غير المصرح بها.
- 7.7.4 تُحفظ السجلات لمدة لا تقل عن سنة كاملة وتُمنع من الحذف أو التعديل دون موافقة مدير تقنية المعلومات.
- 7.7.5 تُزامن جميع الأنظمة على توقيت مركزي موحد لضمان دقة الطوابع الزمنية في السجلات.
- 7.8 حماية الخوادم والبنية التحتية
- 7.8.1 يجب أن تُستضاف أنظمة الموقع والتطبيق على خوادم آمنة ضمن بيئة محلية أو سحابية معتمدة متوافقة مع ضوابط الهيئة الوطنية للأمن السيبراني.
- 7.8.2 يجب تقييد الوصول إلى الخوادم باستخدام VPN داخلي وتطبيق المصادقة المتعددة.
- 7.8.3 يُلزم الفريق التقني بتشفير البيانات المخزنة على الخوادم باستخدام خوارزميات AES-256 أو أعلى.
- 7.8.4 يجب إجراء فحص دوري للأداء والسعة لضمان استقرار الخدمة وحماية توافر النظام (Availability).
- 7.8.5 تُمنع أي تغييرات في إعدادات السيرفر دون موافقة خطية من مدير تقنية المعلومات.
- 7.9 النسخ الاحتياطي واستعادة البيانات
- 7.9.1 يجب إجراء نسخ احتياطي يومي لتقاني لكامل محتوى الموقع والتطبيق وقواعد البيانات.
- 7.9.2 يجب الاحتفاظ بنسخة خارجية مشفرة (Offsite Encrypted Backup) في بيئة مستقلة عن بيئة الإنتاج.
- 7.9.3 يُختبر نظام الاستعادة (Recovery Test) كل ربع سنة للتحقق من سلامة النسخ وقابليتها للاسترجاع.
- 7.9.4 تُسجل جميع عمليات النسخ والاستعادة في سجل مركزي للمراجعة الدورية من إدارة الأمن السيبراني.
- 7.10 إدارة النسخ البرمجية والتحديثات
- 7.10.1 يجب استخدام نظام تحكم في الإصدارات (Version Control System) مثل Git لتتبع جميع التغييرات البرمجية.
- 7.10.2 يُحظر النشر المباشر إلى بيئة التشغيل دون المرور بمرحلة اختبار ومراجعة أمنية.
- 7.10.3 تُنفذ جميع عمليات النشر وفق آلية CI/CD مع مراقبة تلقائية لأي خطأ أثناء النشر.
- 7.10.4 يجب حفظ سجل للإصدارات يشمل التغييرات، المبررات، والمطور المنفذ، وتاريخ الاعتماد.
- 7.11 إدارة اللغات والمحتوى المحلي
- 7.11.1 يجب أن يتوافر المحتوى الرسمي باللغتين العربية والإنجليزية على الأقل، مع الالتزام بالدقة اللغوية.

- 7.11.2 يُلزم فريق المحتوى بمراجعة الترجمة المعتمدة من الجهة القانونية أو وحدة الامتثال قبل النشر.
- 7.11.3 يجب توحيد المصطلحات المستخدمة بين الموقع والتطبيق لضمان وضوح الرسائل للمستخدم.
- 7.12 الخصوصية وملفات الارتباط (Cookies)
- 7.12.1 يجب توضيح سياسة الخصوصية بوضوح للمستخدمين قبل جمع أي بيانات.
- 7.12.2 يُمنع جمع أو تخزين أي بيانات شخصية دون موافقة صريحة من المستخدم.
- 7.12.3 يجب تطبيق لافتة تنبيه (Cookie Banner) توضح استخدام ملفات الارتباط، وتتيح للمستخدم خيار القبول أو الرفض.
- 7.12.4 يجب تشفير جميع بيانات التصفح والتحليلات باستخدام مفاتيح آمنة ومجهولة الهوية (Anonymized Tokens).
- 7.13 إدارة الوصول للنظام الإداري (CMS)
- 7.13.1 يجب منح صلاحيات الوصول إلى لوحة التحكم وفق مبدأ الحد الأدنى من الامتيازات.
- 7.13.2 يُحظر استخدام الحسابات المشتركة في نظام إدارة المحتوى.
- 7.13.3 يجب تسجيل جميع أنشطة المستخدمين داخل لوحة التحكم في نظام التتبع الآلي.
- 7.13.4 تُراجع حسابات CMS كل 3 أشهر للتحقق من صلاحياتها واستمرار الحاجة إليها.
- 7.14 الاستجابة للحوادث
- 7.14.1 يجب على كل مستخدم أو مسؤول إبلاغ فريق الأمن السيبراني فور اكتشاف أي سلوك مشبوه أو اختراق محتمل.
- 7.14.2 تُفعل خطة الاستجابة للحوادث خلال ساعة واحدة من رصد الحادث، وتوثق جميع الإجراءات المتخذة.
- 7.14.3 تُنفذ مراجعة ما بعد الحادث (Post-Incident Review) لتحديد الأسباب الجذرية ومنع تكرارها.
- 7.14.4 تُحدث سياسات الأمان والإجراءات الوقائية بناءً على نتائج التحقيقات الأمنية.
- 7.15 التدريب والوعي
- 7.15.1 يجب تدريب جميع العاملين في إدارة الموقع أو التطبيق على الأمن السيبراني والنشر الآمن مرتين سنوياً على الأقل.
- 7.15.2 يُلزم الفريق التقني بإكمال دورات تخصصية في "تأمين التطبيقات" و "إدارة الثغرات الإلكترونية".
- 7.15.3 تُوثق جميع البرامج التدريبية وتُراجع سجلات الحضور سنوياً ضمن تقييم الامتثال الأمني للشركة.
8. مسؤولية السياسة.
- 8.1 إدارة تقنية المعلومات:
- 8.1.1 مسؤولون عن تطبيق هذه السياسة، ومتابعة تنفيذ ضوابطها الفنية والتشغيلية، وضمان امتثال الموقع الإلكتروني والتطبيق لمتطلبات الأمن السيبراني وحماية البيانات.
- 8.2 إدارة المبيعات والتسويق:
- 8.2.1 مسؤولون عن إعداد وتحديث المواد الخاصة بالمحتوى عبر القنوات الرسمية والتنسيق المسبق مع إدارة تقنية المعلومات لضمان التوافق مع متطلبات الأمان والجودة.
- 8.3 إدارة الجودة والتطوير:
- 8.3.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.
9. التعاميم والتعليمات ذات العلاقة:
- 9.1 الضوابط الأساسية للأمن السيبراني الصادرة عن الهيئة الوطنية للأمن السيبراني (NCA ECC-1:2018).
- 9.2 لائحة الأمن السيبراني الوطنية إصدار 2022.
- 9.3 لائحة حماية البيانات الشخصية الصادرة عن الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA PDPL).
- 9.4 دليل الأمن السيبراني وإدارة الأنظمة الصادر عن هيئة الحكومة الرقمية (DGA).
- 9.5 تعليمات هيئة التأمين السعودية بشأن حماية بيانات العملاء وأنظمة التشغيل الإلكترونية.
10. احفظ السياسة:
- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايمنود المعتمدة.



إدارة الجودة والتطوير
Quality & Development Management



Diamond Insurance Broker

Website and Mobile Application Management Policy

Nov 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY

Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction:

1.1 The Website and Mobile Application Management Policy is a fundamental policy for governing the development, operation, maintenance, and management of the website and mobile application. It ensures compliance with applicable technical, regulatory, and security requirements issued by competent authorities, while safeguarding data, ensuring service continuity, and enhancing the user experience.

2. Policy Objective:

2.1 Diamond Document Insurance Brokers Company (hereinafter referred to as "Shahin") believes that the objective of this policy is to define the governing controls and standards for managing, operating, and maintaining the website and mobile application. This includes protecting the digital infrastructure and public content from unauthorized access, breach, or modification; ensuring the reliability, accuracy, and integrity of published information; complying with secure design standards and personal data protection requirements; enhancing user experience; ensuring service stability and continuity; and unifying operational procedures among the departments responsible for content, technology, and cybersecurity.

3. Definitions:

3.1 Shahin Platform: The Company's digital platform, operating as an insurance broker that connects with insurance companies to facilitate issuance, renewals, and electronic customer management.

3.2 Website: The public digital platform through which the Company's services and content are made available online.

3.3 Mobile Application: The dedicated software application that enables customers or users to access the Company's services via smart devices.

3.4 User: Any individual authorized to access the website or application, whether an employee, customer, or approved external party.

3.5 Content: Text, images, links, forms, or any data displayed on the website or application.

3.6 Technical Manager: The person responsible for operating and managing the technical infrastructure and ensuring the integrity of digital systems.

3.7 Cybersecurity: A set of measures and controls intended to protect digital systems against threats and cyberattacks.

3.8 Content Management System (CMS): The internal system used to create, edit, and update website or application content.

3.9 Incident Response Plan: The procedures followed to address any security incident or potential breach.

3.10 Backup: The process of saving a copy of data to enable restoration in case of loss or failure.

3.11 Multi-Factor Authentication (MFA): A verification mechanism that relies on more than one method to confirm user identity before granting access.

4. Scope of Application:

4.1 This policy applies to:

4.1.1 Permanent and temporary employees.

4.1.2 External contractors and consultants.

4.1.3 External technical service providers and support companies whose personnel are granted access to any Company system.

5. Related Management and Sectors:

5.1 Information Technology Department.

5.2 Cybersecurity Unit/Department.

5.3 Sales and Marketing Department.

6. Related Entity:

6.1 National Cybersecurity Authority (NCA).

6.2 Saudi Data and Artificial Intelligence Authority (SDAIA).

6.3 Digital Government Authority (DGA).

6.4 Saudi Insurance Authority.

6.5 External technical service providers, customers, and end users.

7. General Rules:

7.1 General Compliance:

7.1.1 All employees, contractors, and external parties must comply with this policy when managing, developing, or updating the website or mobile application content.

7.1.2 Each user or system administrator must fully comply with the requirements of the National Cybersecurity Authority (NCA), the Digital Government Authority (DGA), and the Insurance Authority instructions regarding customer data protection and electronic systems management.

7.1.3 No changes to the design, structure, or content of the website or application may be implemented without written approval from the Information Technology Department.

7.1.4 Publishing any content or integrating external systems is prohibited without prior security review.

7.1.5 This policy shall be reviewed at least annually to ensure alignment with the latest technical and regulatory updates.

7.2 Content Management:

7.2.1 All publishing and updating activities for the website and application must be managed through the Information Technology Department in coordination with the content owner (Sales and Marketing) to ensure accuracy, consistency, and regulatory compliance.

7.2.2 All content changes must be documented in an electronic log including: publication/update date, implementer name, and change type (add, delete, edit).

7.2.3 Content must be reviewed and approved by the competent department prior to publication to ensure compliance with Company policies, data protection standards, and Insurance Authority requirements.

7.2.4 Publishing any content that includes sensitive information, customer data, or internal operational details not authorized for public disclosure is prohibited.

7.2.5 The technical team must ensure that published content is free of malicious scripts or untrusted links.

7.2.6 Content must be updated periodically, at a minimum once every six (6) months, to ensure information remains

current and accurate.

7.2.7 User Experience (UX) and ease of navigation standards must be applied when designing or updating pages and visual components of the website and application.

7.2.8 All uploaded files and media must undergo security scanning prior to being uploaded to servers to prevent vulnerabilities or malware.

7.2.9 Modifying or deleting any published content is prohibited without prior approval from the IT Manager or an officially authorized delegate.

7.2.10 The IT Department shall review the operational performance of the website and application monthly, including loading speed, incidents, and content stability presented to users.

7.2.11 A backup copy of all published content must be retained prior to any material change, with the ability to restore when needed (Version Control).

7.3 Secure Design and Development:

7.3.1 The website and application must be developed and maintained under the "Secure by Design" principle, including input validation, session management, and access control.

7.3.2 The development team must apply all software patches and updates promptly upon release, after testing them in an isolated environment.

7.3.3 Internal and external penetration tests must be conducted at least annually and after any major update.

7.3.4 All components (Plugins / APIs / Frameworks) must undergo security assessment prior to integration.

7.3.5 The use of open-source libraries or tools is prohibited unless their security has been assessed and formally approved by the IT Department.

7.4 Protection of Data and Public Content:

7.4.1 All publicly displayed data must be protected from unauthorized modification or exploitation through strict access controls (Access Control Lists).

7.4.2 The technical team must use encrypted communication protocols (TLS 1.2 or higher).

7.4.3 Daily automated backups must be performed for website and application data, and backup copies must be stored in a secure, segregated location.

7.4.4 No public data-input form may be developed without robust input validation controls.

7.4.5 Administrative user privileges must be reviewed monthly, and any account inactive for thirty (30) days must be disabled.

7.5 Monitoring and Vulnerability Detection:

7.5.1 Periodic vulnerability scanning must be performed at least quarterly for each technical component within the website or application.

7.5.2 Vulnerabilities must be classified by severity (Critical / High / Medium / Low), and critical vulnerabilities must be remediated within no more than seven (7) business days.

7.5.3 Advanced monitoring tools (SIEM / IDS / WAF) must be used to detect unauthorized activities and alert the security team immediately.

7.5.4 All vulnerabilities and remediation outcomes must be documented in an official register subject to Cybersecurity

review.

7.5.5 Secure configuration standards must be updated periodically based on scanning and testing results.

7.6 Updates and Fix Management:

7.6.1 The IT team must monitor security updates released by approved software vendors.

7.6.2 Updates must be tested in a staging environment prior to deployment to production.

7.6.3 Each update implementation must be documented in a log including: system name, update type, deployment date, and outcome.

7.6.4 Successful security patch deployment must be confirmed through post-deployment verification testing.

7.6.5 Backup systems must be reviewed after each update to ensure stability and restore capability when needed.

7.7 Monitoring and Audit:

7.7.1 Security logging must be enabled for all systems connected to the website and application.

7.7.2 Logs must be sent to a protected central system and reviewed weekly to detect anomalous behavior.

7.7.3 File Integrity Monitoring tools must be used to detect unauthorized changes.

7.7.4 Logs must be retained for at least one (1) full year and may not be deleted or modified without IT Manager approval.

7.7.5 All systems must be synchronized to a unified central time source to ensure accurate log timestamps.

7.8 Server and Infrastructure Protection:

7.8.1 Website and application systems must be hosted on secure servers within an approved local or cloud environment compliant with NCA requirements.

7.8.2 Server access must be restricted through internal VPN and multi-factor authentication.

7.8.3 Stored data on servers must be encrypted using AES-256 or higher.

7.8.4 Periodic performance and capacity assessments must be performed to ensure service stability and protect system availability.

7.8.5 No server configuration changes may be performed without written approval from the IT Manager.

7.9 Backup and Data Recovery:

7.9.1 Automated daily backups must be performed for the full website/application content and databases.

7.9.2 An offsite encrypted backup copy must be maintained in an environment independent from production.

7.9.3 Recovery testing must be conducted quarterly to validate backup integrity and restorability.

7.9.4 All backup and restore activities must be logged in a central register for periodic Cybersecurity review.

7.10 Software Version and Deployment Management:

7.10.1 A version control system such as Git must be used to track all code changes.

7.10.2 Direct deployment to production is prohibited without testing and security review.

7.10.3 Deployments must be executed through CI/CD processes with automated monitoring for deployment errors.

7.10.4 A release log must be maintained including changes, rationale, developer name, and approval date.

7.11 Language and Localization Management:

7.11.1 Official content must be available at minimum in Arabic and English, with linguistic accuracy and consistency.

7.11.2 The content team must ensure that approved translations are reviewed by the legal function or the compliance unit

prior to publication.

7.11.3 Terminology must be standardized across the website and application to ensure clarity of messaging.

7.12 Privacy and Cookies:

7.12.1 The privacy policy must be clearly presented to users prior to collecting any data.

7.12.2 Collecting or storing any personal data without explicit user consent is prohibited.

7.12.3 A cookie banner must be implemented to explain the use of cookies and enable users to accept or reject.

7.12.4 Browsing and analytics data must be protected through secure and anonymized tokens.

7.13 Admin Access (CMS) Management:

7.13.1 CMS access privileges must be granted based on the principle of least privilege.

7.13.2 Shared accounts within the CMS are prohibited.

7.13.3 All user activities within the CMS must be logged in an automated tracking system.

7.13.4 CMS accounts must be reviewed every three (3) months to validate permissions and continued necessity.

7.14 Incident Response:

7.14.1 Any user or administrator must report any suspicious behavior or potential breach to the Cybersecurity team immediately upon detection.

7.14.2 The incident response plan must be activated within one (1) hour of incident detection, and all actions must be documented.

7.14.3 A post-incident review must be conducted to identify root causes and prevent recurrence.

7.14.4 Security policies and preventive procedures must be updated based on investigation outcomes.

7.15 Training and Awareness:

7.15.1 All staff involved in website/application management must receive cybersecurity and secure publishing training at least twice annually.

7.15.2 The technical team must complete specialized courses in "Application Security" and "Vulnerability Management."

7.15.3 All training programs must be documented, and attendance records must be reviewed annually as part of the Company's security compliance assessment.

8. Policy Responsibility:

8.1 Information Technology Department:

8.1.1 Responsible for implementing this policy, ensuring execution of technical and operational controls, and ensuring that the website and mobile application comply with cybersecurity and data protection requirements.

8.2 Sales and Marketing Department:

8.2.1 Responsible for preparing and updating content materials through official channels and coordinating in advance with the IT Department to ensure alignment with security and quality requirements.

8.3 Quality and Development Department:

8.3.1 Responsible for verifying implementation of this policy through periodic audits and reviews.

9. Related Circulars and Instructions:

9.1 Essential Cybersecurity Controls issued by the National Cybersecurity Authority (NCA ECC-1:2018).

9.2 National Cybersecurity Regulation (2022 edition).

9.3 Personal Data Protection Law (PDPL) issued by SDAIA.

9.4 Cybersecurity and Systems Management Guide issued by the Digital Government Authority (DGA).

9.5 Saudi Insurance Authority instructions regarding customer data protection and electronic operating systems.

10. Policy Retention:

10.1 The approved non-editable electronic version of this policy shall be stored in the Human Resources System and made accessible to relevant departments.

10.2 The approved hard copy shall be retained by the Quality and Development Department in accordance with the statutory retention period specified in the Document Retention Manual and archived accordingly.

11. Policy Violation:

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond's approved Disciplinary and Sanctions Policy.

